

Stored XSS allowing attacker inject malicious script

Author: Spycio.Kon

Date: 01/01/2026

Environment: test on Kirby's core application 5.2.1

Link: <https://github.com/getkirby/kirby/archive/refs/tags/5.2.1.zip>

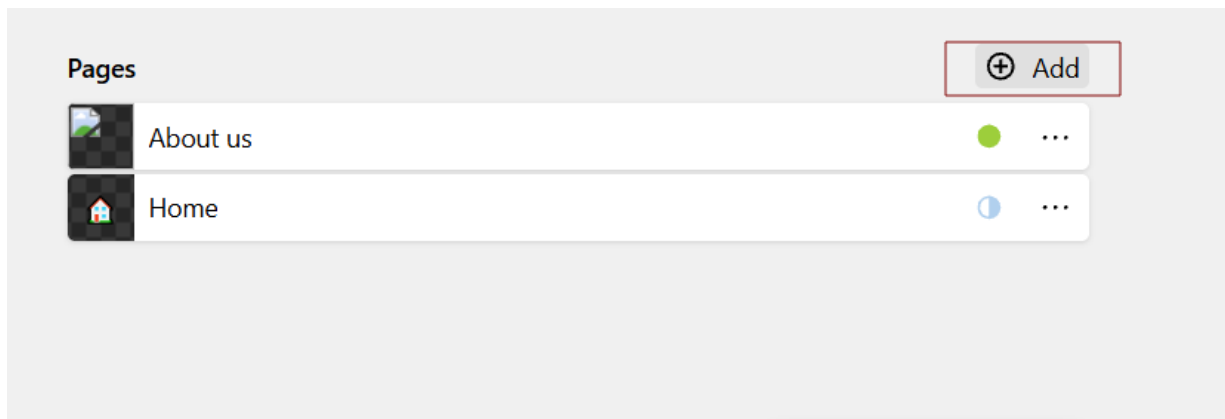
Description: The vulnerable exist in the */panel/pages*. If any users view the affected content, the malicious code would be executed

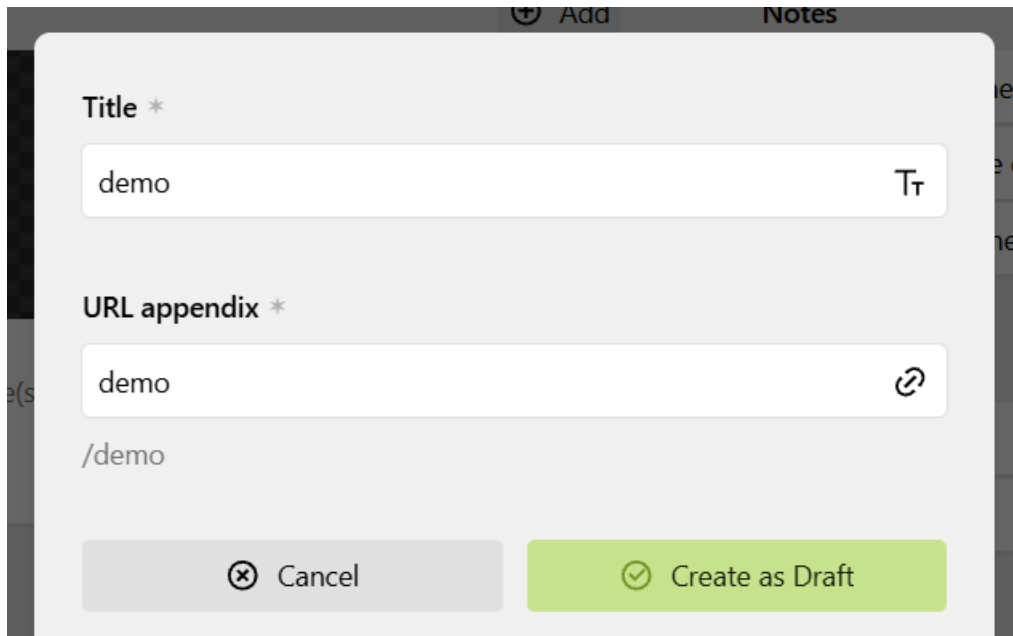
Impact:

Because the payload is stored, this attack does not require repeated interaction from the attacker and can affect multiple users, leading to account compromise, data manipulation, or full takeover of the administrative Panel by using other endpoint

Reproduce

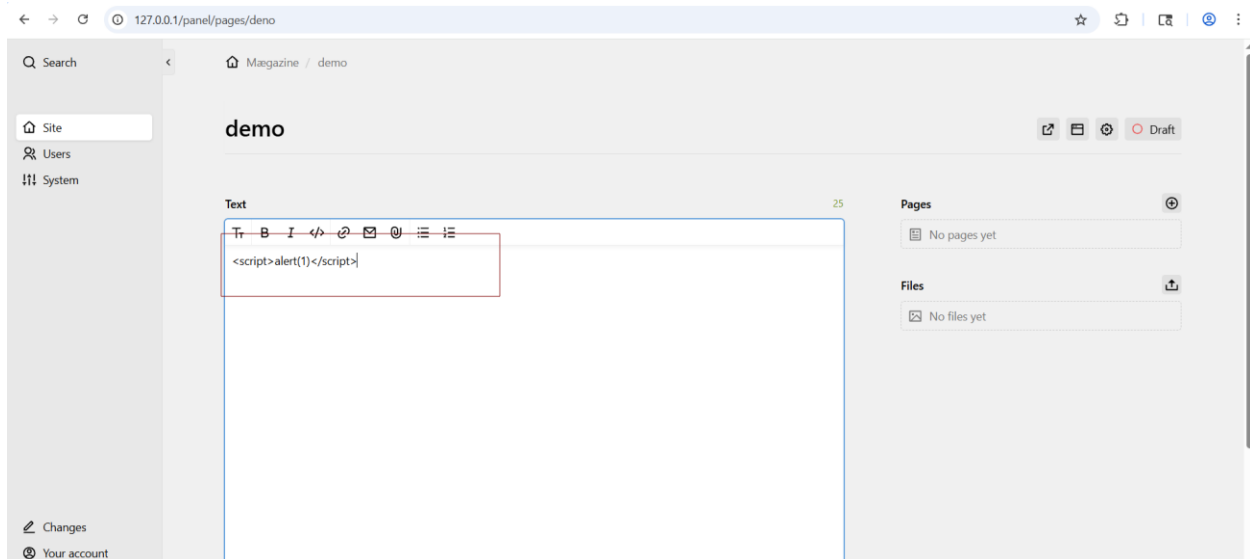
Step1: Create a new sample page



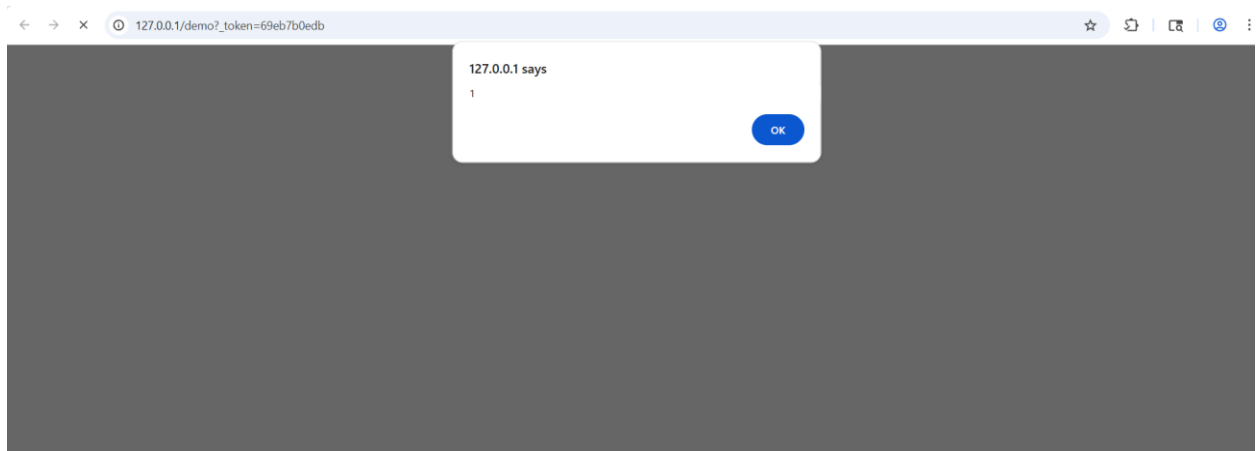


The image shows a modal window titled "Notes" with a dark header bar containing a plus icon and the word "Add". The modal has a light gray background and contains two text input fields. The first field is labeled "Title *" and contains the text "demo". The second field is labeled "URL appendix *" and contains the text "demo". Below the second field, the text "/demo" is visible. At the bottom of the modal, there are two buttons: a gray "Cancel" button with a close icon and a green "Create as Draft" button with a checkmark icon.

Step2: Inject a malicious script into text box and save



Step3: When click open or preview, the script will be excute



Suggestion: Title input should be santinize before render